

So: yesterday we answered the question of: What is Alice allowed to access? But Today, we want to focus on: If I didn't watch Alice use the computer, could I reconstruct what she did from Windows security evidence? (This is security analysis)

Goals:

- Be able to explain what Windows security auditing is
- Explain Event IDs 4624 and 4625
- Verify whether CLIENT01 audits successful/failed logons
- Generate controlled authentication activity
- Find evidence without being told every click
- Interpret important fields inside an event
- Understand why the client and DC may contain different evidence
- Query logs outside of manually scrolling Event Viewer
- Build your first authentication timeline
- Write a small analyst-style conclusion
- Pass a short blind competency test

Event 4624 = successful logon, 4625 = failed logon

Closed-Book Review

What is the difference between authentication and authorization?

Authentication is proving identity (username, passwd, token, face, etc)...Authorization is what you are allowed to do once you have been authenticated.

Explain this: ahr -> GG_HR_Users -> DL_HR_Share_Modify -> HR Share

Why aren't we granting Alice permission directly?

AGDLP implementation, we don't want to touch resource permissions directly on an account.

This affects how scalable something is.

What is the difference between an SMB share permission and an NTFS permission?

SMB = server message permission....directories and content over the network to a shared folder, while NTFS permissions deal with direct files and folders (on disk).

Why does CLIENT01 use SRV-DC01 for DNS?

CLIENT01 points to SRV-DC01 for DNS because in AD domain, DNS is how the client finds the domain controller and services.

What does a computer secure channel represent?

Trusted encrypted relationship between a joined computer in the domain and the controller, lets the computer securely authenticate and use domain services.

What did gpupdate /force?

Instantly re-apply the Group Policy settings

What did gpresult /r prove?

It shows what group policy objects are applied, so we knew our GPO was applied.

What is Event ID 4688?

A new process has been created

If Alice can log into Windows but receives Access Denied opening Finance: Authentication problem or authorization problem? Explain.

Authorization. She's already been authenticated in logging into Windows. Being denied permissions to open Finance has to do with Authorization.

Which Domain Control authenticated Alice? What command or evidence did you previously use to answer that?

SRV-DC01 authenticated Alice. nltest /dsgetdc.kevinlab.local

Learn the New Concept

Moving from configure security to: observe activity -> collect evidence -> interpret evidence -> reconstruct what occurred.

Scenario: Your manager tells you Alice's account may have had suspicious authentication activity at 11:42 PM.

But...I wasn't there....I can't ask Windows if Alice was hacked? But, I have evidence....One source is the Windows Security log. The two events I need today are 4624 and 4625.

The Event ID tells you what occurred. The Logon Type helps tell you how, 2 = Interactive (sitting at the screen), 3 = Network (accessing resource over the network, opening shared folder or accessing a printer), 10 = RemoteInteractive (remote session, rdp)

Challenge 1: Audit Readiness

Determine whether CLIENT01 is currently configured to record both successful and failed user logons.

Determine:

1. Which auditing category should logically contain user logon activity?
 - a. In Event Viewer, an auditing category is within Windows logs, and it is either: Security, System, or Application. **It is in Security.**
2. Is success enabled?
 - a. **It appears not enabled..**
3. Is failure enabled?
 - a. **It appears not enabled..**

4. If one isn't enabled, how should your existing workstation-security GPO be modified?
 - a. **Go to Group Policy Manager on Server VM, edit the current GPO. Click success and failure for account logon.**
5. How can you prove the resulting policy actually reached CLIENT01?
 - a. **gpresult /r and then obviously do the testing with the logon**

Challenge 2: Generate Evidence

Scenario: Alice tries to authenticate to CLIENT01 once with an incorrect password and later authenticates successfully.

1. How could I generate a controlled failed authentication?
 - a. **Log onto ahr account using wrong password.**
2. How could I then generate a successful authentication?
 - a. **Log onto ahr account using the right password.**
3. Which machine should have evidence?
 - a. **Client PC. Refer to self-note.**
4. Which Event IDs do I expect?
 - a. **4625 -> 4624...**
5. What approximate timestamps should I record?
 - a. **8/9/2026 5:48:41 PM for the logon failed, 8/9/2026 5:45:58 PM for logon successful**

Self note: IT would get these logs centrally, currently checking the CLIENT01 logs locally which will be developed further later on.

Self-note: Logon type 11 is a cached interacting logon. Windows is letting a user login using cached domain credentials (previously saved logon credentials)

Self-note: Logon type 7 is unlocked. When someone unlocks an existing session.

Challenge 3: Investigate

Now pretend you didn't generate those events.

Assignment: Find evidence supporting the statement that Alice first failed to authenticate and later successfully authenticated. For the failed event and successful events, record whatever fields Windows gives.

Failed Logon Attempt:

Keyword: Audit Failure

Date and Time: 8/9/2026 5:48:41PM

Source: Microsoft Windows Security Auditing

Event ID: 4625

Task Category: Logon
Logon Type: 2
Account Name: ahr
Failure Reason: Unknown user name or bad password

Successful Logon Attempt:
Keyword: Audit Success
Date and Time: 8/9/2026 5:48:58 PM
Source: Microsoft Windows Security Auditing
Event ID: 4624
Task Category: Logon
Logon Type: 11
Account Name: ahr
Account Domain: KEVINLAB
Workstation Name: CLIENT01

Client vs Domain Controller Investigation

I have: CLIENT01 and SRV-DC01.

Reminder: Domain Controller is a Windows Server running AD. It authenticates users.

Would these two computers necessarily record identical evidence?

No. One is the workstation where activity happens. One is providing domain services.
Challenge: Investigate both Security logs around your test time.

SRV-DC01: There are no 4625 logs on the server-side of things, but there are 4624 logs.

They are different because they play different roles. CLIENT01 is what happens on the workstation. SRV-DC01 is what the domain controller does.

Stop Using Only the GUI

Objective: Find a PowerShell cmdlet capable of reading Windows Event Logs.

Get-WinEvent -LogName Security (events from security log, will keep going on forever)

Get-WinEvent -LogName Security -MaxEvents 10 (only 10 most recent events)

Get-WinEvent -FilterHashtable @{LogName='Security'; ID=4624,4625} -MaxEvents 10